

ラボ4.2: パスワードファジング

1. はじめに

1.1. 必要なリソース

- ControlThings プラットフォーム VM

1.2. 概要

このラボでは、「Dojo Control」というウェブアプリケーションの脆弱性を調査します。これは、エンジニアやオペレーターがシフト中に何が起きたかを記録するためのシフトログアプリケーションです。ユーザーのパスワードをファジングすることで、ブルートフォース攻撃を試みます

1.3. 目標

- ZAPを使用して生のHTTPログインリクエストを調べる
- ウェブアプリケーションでパスワードファジングを実行する
- ファジングの出力を分析して、どの試みが成功したかを特定する

2. DojoControl Shift-Logger

Webアプリケーションの認証プロセスを見ていきます。このWebアプリケーションはICSシステムの一部ではありませんが、ここで検証する認証プロセスと脆弱性は、WebベースのHMIやICS管理インターフェースに見られるものと似ています。ICS担当者が認証情報に強力なパスワードを選択しない場合、攻撃者は既知のユーザーのパスワードをファジング（パスワード推測とも呼ばれます）することで、アプリケーションへの総当たり攻撃を試みることができます。これがこのラボで行うことです

これから確認するWebアプリケーションは、ControlThings仮想マシン上でブラウザを開き、アドレスバーに「localhost」と入力することで見つけることができます。このラボの目標は、ユーザー「john」のパスワードをファジングすることです。そのためには、Zed Attack Proxy（略してZAP）というセキュリティテストツールと、John the Ripperというツールから入手した一般的なパスワードリストを使用します。

ControlThings Platform VMを起動する

Firefoxを開いて localhost

前回のラボから既に Dojo Control Web アプリケーションにログインしている場合は、続行する前に必ずログアウトしてください。

ログインメニュー項目をクリックします

✓ 成功

Welcome to Dojo Control's Shift Logger!

Not logged in

Main Menu

[Home](#)
[Register](#)
[Login](#)

Pentester Help

[About](#)
[Toggle Hints](#)
[Vuln List](#)
[Credits](#)
[Reset DB](#)

Login

If you do not have an account, [Register](#)

Enter your username and password:

Name:

Password:

これはDojoControlアプリケーションです。オペレーターがシフト中に発生した問題や対処方法を記録するためのシンプルなシフトログアプリケーションを模倣して作成されました。これにより、後続のオペレーターはプロセスで以前に発生した事象の履歴を確認できます。

これを本番環境で使用しないでください。

このアプリケーションは、OWASP Top 10 のウェブ脆弱性すべてに加え、その他の脆弱性に対して脆弱です。本アプリケーションは教育目的のみで作成されました。

3. 手動推測

Dojo Controlは、Webアプリケーションのセキュリティテストの実行方法を教えるために作成したWebアプリケーションです。本日は、これを使用してパスワードファジング攻撃を実演します。このラボで悪用する弱点は、Webアプリケーションの脆弱性ではなく、各ユーザーが選択したパスワードです。アカウントロックアウトなどの防御策をWebアプリケーションに追加することもできますが、安全上の懸念から、ICS環境では必ずしも適切ではありません

ユーザーのパスワードをいくつか推測してみましょう john

もちろん、数回試ただけでは正しいパスワードを推測できる可能性はかなり低いですが、今は失敗した応答ページがどのようなものかということの方が重要です。この失敗した応答ページはラボの少し後で使用しますが、今は、正しいパスワードを選択しな

いと「ユーザー名またはパスワードが正しくありません」と表示されることだけに注目してください。これは、Web アプリケーションがユーザー名、パスワード、またはその両方が間違っているかどうかを明らかにしないため、良いことです。これは好ましいことです。このラボでは、おそらく以前攻撃した他のマシンで john の名前を見たか、LinkedIn を使用して john がこの組織のコントロール オペレーターであることを確認したことにより、john が有効なユーザー アカウントであることを把握していると想定しています。

4. Firefoxの設定

次に、認証時にウェブブラウザがウェブサーバーに実際に何を送信しているかを確認するために、2つ目のツールを使用します。そのためには、Zed Attack Proxy (ZAP) と呼ばれるツールを使用して、ウェブブラウザからの生のHTTPリクエストを確認します。ZAPを開く前に、ControlThings仮想マシンでFirefoxブラウザをプロキシとしてZAPを使用するように設定する必要があります。これは、FirefoxがすべてのデータをZAPに送信し、ZAPが正しいウェブサーバーに送信することを信頼することを意味します。

Firefox と ZAP を併用するには、Firefox に最近追加されたセキュリティ防御を無効にする必要があります。具体的には、マルウェアがユーザーのブラウザセッションを追跡するためにこの手法を使用しているため、Firefox はローカルホストのウェブサイトへのプロキシを許可していません。

Firefoxを変更してローカルホストのハイジャックを許可する

Firefox で新しいタブを開き、に移動して `about:config` に設定し `network.proxy.allow_hijacking_localhost` を `true` 。

? それはどうやってやるんですか?

タブエリアのプラス記号をクリックして新しいタブを開きます

アドレスバーに次のように入力します `about:config`

これにより、Windows のレジストリと同様に、Firefox の下位レベルの設定にアクセスできるようになります。

警告を受け入れる

ここで変更を行うと保証が無効になる可能性があるという警告が表示されます。「**リスクを承知で!**」ボタンをクリックしてください。

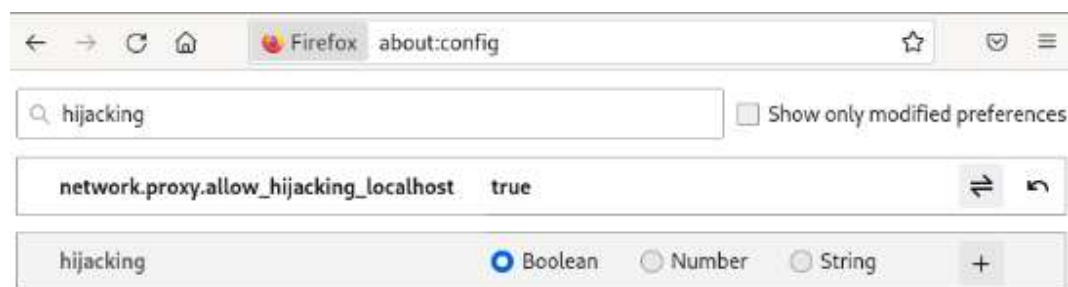
検索 hijacking

これにより、設定リストが必要なものだけに絞り込まれます。

`allow_hijacking_localhost` 行をダブルクリックします

これにより、**値**の設定がに変更されます `true` 。

✓ 成功



`about:config`タブを閉じてください

最初のタブに戻り、DojoControlのウェブサイトが表示されます

それが完了したら、次に、ZAP をプロキシとして使用するように Firefox を設定する必要があります。

Firefoxの設定を開き、`localhost:8080` すべてのプロトコルで使用するよう設定します

? それはどうすればいいですか?

Firefoxの設定を開く

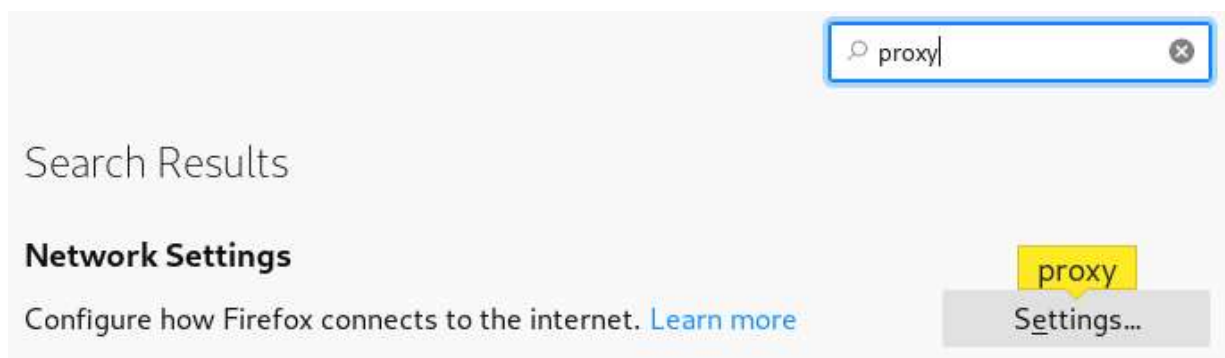
Firefoxの右上隅にある  アイコンをクリックします

メニューから設定を選択します

上部の「設定で検索」ボックスで、 proxy

これにより、設定が1つの項目に絞り込まれます。

✓ 成功



設定ボタンをクリックします

このスクリーンショットに合わせて変更を加えます

警告: チェックボックスを忘れないでください **Also use this proxy for HTTPS**

Connection Settings

×

Configure Proxy Access to the Internet

☐ No proxy

☐ Auto-detect proxy settings for this network

☐ Use system proxy settings

☒ Manual proxy configuration

HTTP Proxy

localhost

Port

8080

☒ Also use this proxy for HTTPS

HTTPS Proxy

localhost

Port

8080

SOCKS Host

Port

0

☐ SOCKS v4

☒ SOCKS v5

☐ Automatic proxy configuration URL

Reload

No proxy for

Example: .mozilla.org, .net.nz, 192.168.1.0/24

☐ Do not prompt for authentication if password is saved

☐ Proxy DNS when using SOCKS v5

☐ Enable DNS over HTTPS

Use Provider

Cloudflare (Default)

▼

Help

Cancel

OK

[OK]をクリックします

設定タブを閉じる

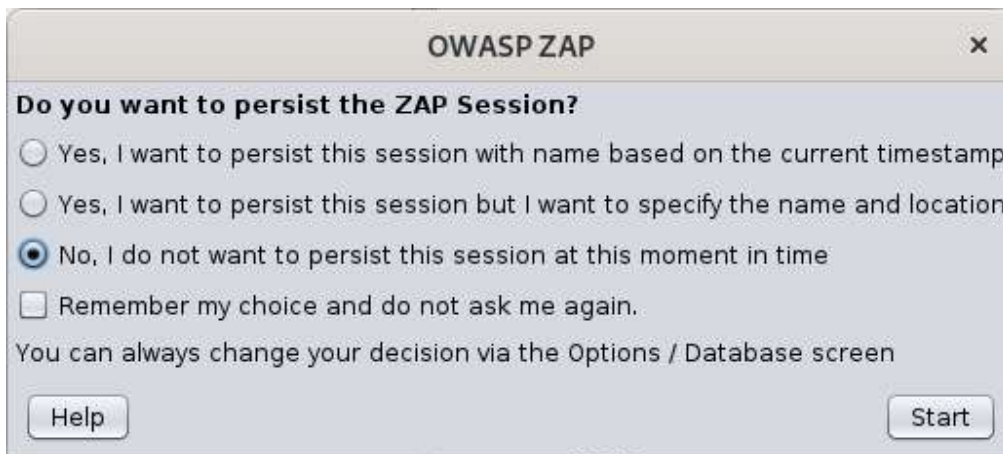
最初のタブに戻り、DojoControlのウェブサイトが表示されます

Firefox は、すべての Web リクエストを に ZAP に送信するようになりました `localhost:8080`。そのため、次のステップである ZAP が実行されるまで、Firefox は Web サーバーと通信できません。

5. ZAPの設定

アクティビティメニューからZAPを検索して起動します**i ZAPセッションを永続化する必要はありません**

ZAP を初めて起動すると、このセッションを継続するかどうかを尋ねられます。「いいえ」と教えてください。



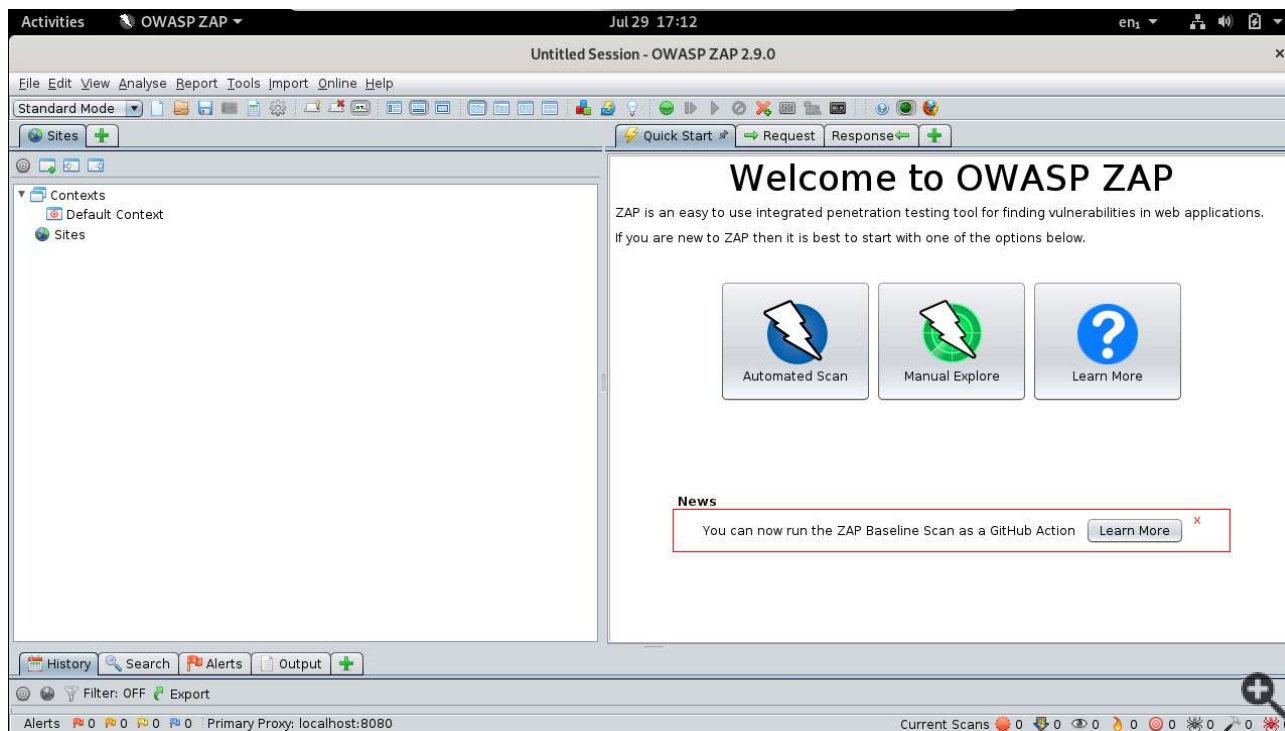
これは、侵入テストを実行して結果をまとめたレポートを作成する場合など、後で参照できるようにアクションを保存する場合に便利です。

i アドオンを更新する必要はありません

ZAP を初めて実行すると、アドオンの更新を促すメッセージが表示されます。このラボの最後には、いくつか便利なアドオンを試すことができますが、今はこのウィンドウを閉じて構いません。

✓ 成功

ZAP ウィンドウは次のようになります。



上記の ZAP の成功インジケータを見ると、タブ付きの 3 つの異なるセクションが表示されます。

1. 左側の「サイト」タブには、各ウェブサイトでアクセスしたすべてのページのツリーが表示されます。このラボでは使用しません。
2. 右側のセクションには、「クイックスタート」、「リクエスト」、「レスポンス」タブがあります。このセクションでは、各リクエストとレスポンスの詳細を確認します。
3. 下部には「履歴」「検索」「アラート」「出力」タブがあります。これらのタブを使って、ファジングする Web リクエストを選択し、ファジング結果を確認します。

これらのセクションが表示されない場合は、折りたたまれている可能性があります。ZAP ウィンドウを最大化しても表示されない場合は、ウィンドウの左下中央または下部にあるハンドルを探してください。ハンドルがあれば、ドラッグしてセクションを展開できます。

また、任意のタブをダブルクリックして最大化し、もう一度ダブルクリックして通常の状態に戻すこともできます。

5.1. CA のエクスポート/インポート

ファジングを行う前に、Firefox でもう 1 つ設定が必要です。現在、すべてのウェブサイトが SSL/TLS を使用しており、すべてのブラウザが SSL/TLS の使用を強制しているため、ZAP の **ルート CA 公開証明書** をエクスポートし、Firefox にインポートする必要があります。

ZAPのオプションウィンドウを開く

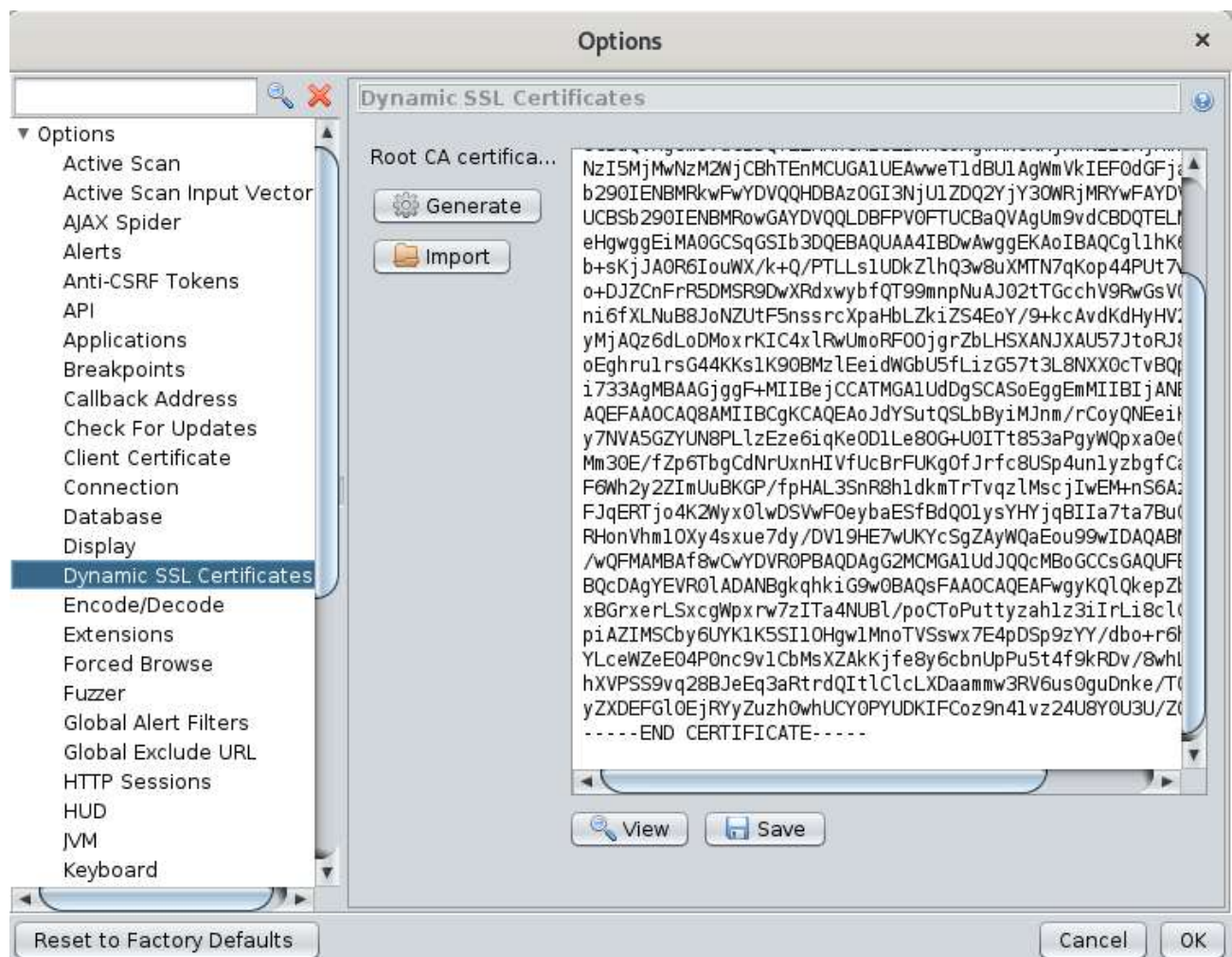
ZAP の[ツール]メニューから[オプション]を選択して、ZAP のメイン構成ウィンドウを開きます。

ZAPのCA証明書を保存する

左側のオプションリストから「動的SSL証明書」を選択してください。このオプションでは、ZAPがすべてのHTTPSトラフィックに動的署名するために使用するSSL/TLS CA証明書を管理できます。ZAPはCA証明書を自動的に生成するので、保存するだけで済みます。

✓ 成功

CA証明書の正確な内容は人によって異なります。



「保存」ボタンをクリックし、推奨される名前で保存してください `owasp_zap_root_ca.cer`。これでホームフォルダに保存されます

ZAPオプションウィンドウを閉じる

ZAP の CA 公開証明書を取得できたので、Firefox に戻ってインポートしましょう。

owasp_zap_root_ca.cer Firefoxにインポート

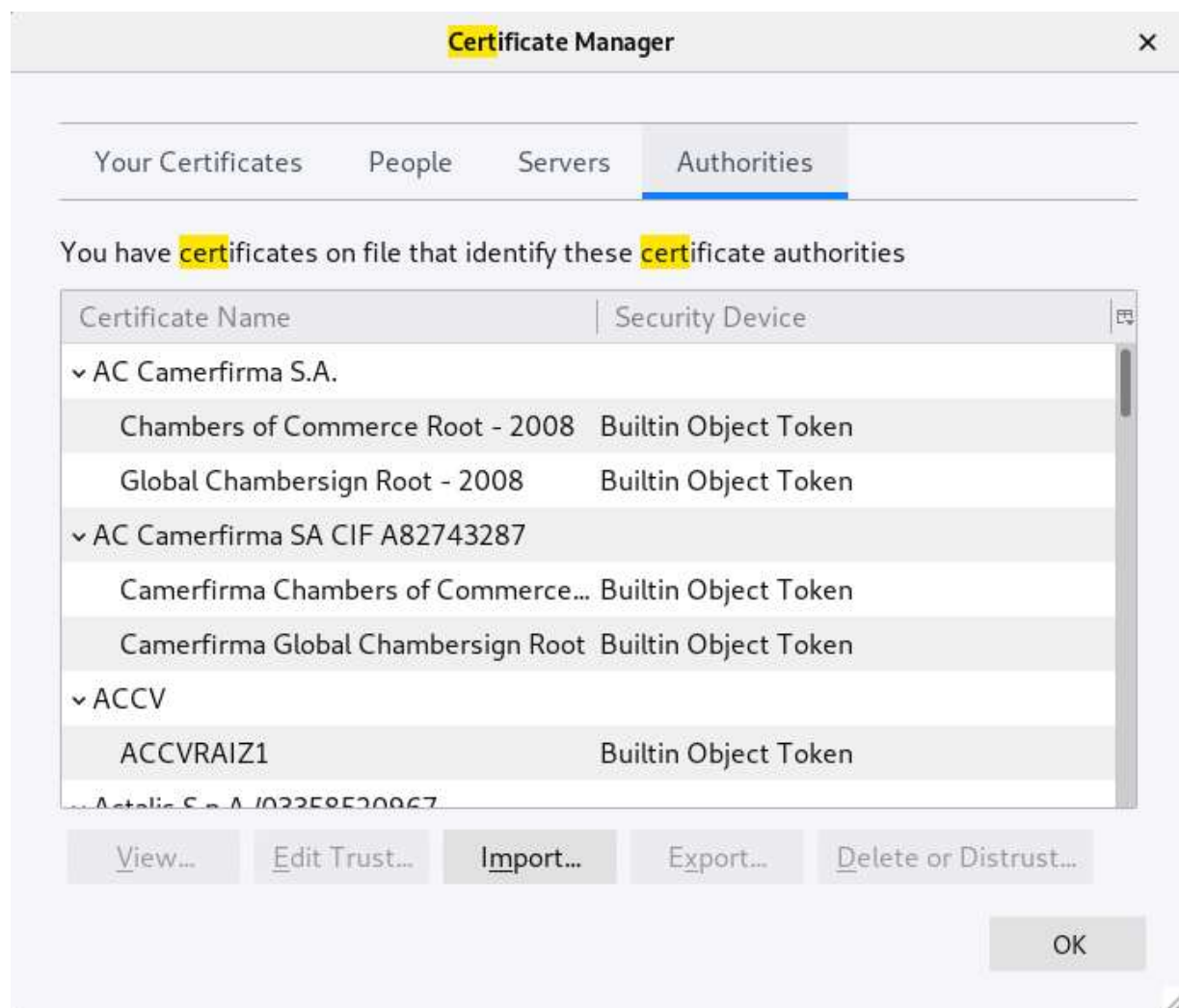
? それはどうすればいいですか?

Firefoxの設定を開く

検索 cert

View Certificates... ボタンをクリック

✓ 成功



Import ボタンをクリックしてください

ホームフォルダに移動して owasp_zap_root_ca.cer ファイルを選択します

ボタンをクリックして `open` 証明書をインポートします

✓ 成功



オプションを選択し `Trust this CA to identify websites` でクリック `OK`

もう一度クリックする `OK` と証明書マネージャウィンドウが閉じます

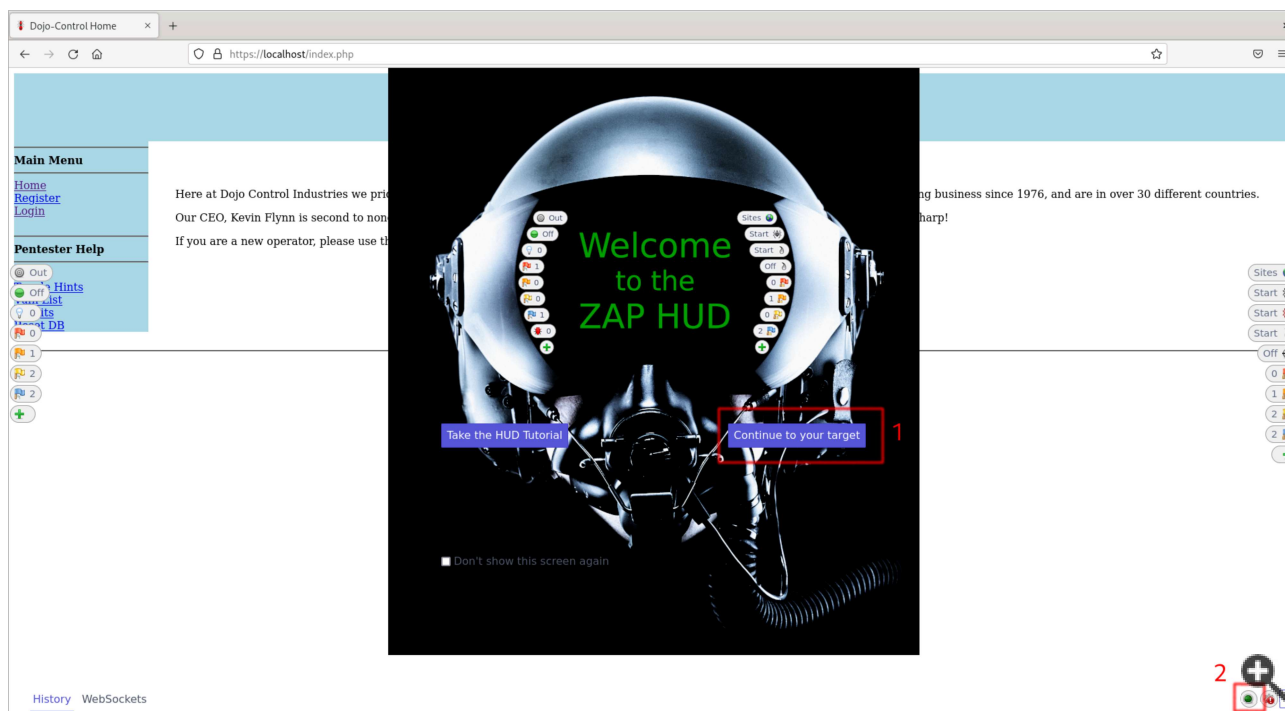
`Settings` タブを閉じる

5.2. リクエストをキャプチャする

ZAP が実行され、Firefox が ZAP にトラフィックを送信するように設定されたので、セットアップを試してみましょう。

FirefoxでDojoControlのWebサイトを更新し、FirefoxがZAP経由で動作していることを確認します。

✓ 成功



✗ エラー: プロキシサーバーが接続を拒否しています

これは通常、Firefoxのプロキシ設定が正しくないか、ZAPが実行されていないために発生します。

✗ エラー: 接続できません

これは通常、Firefoxのプロキシ設定でボックスをオンにし忘れたために発生します **Use this proxy server for all protocols**。

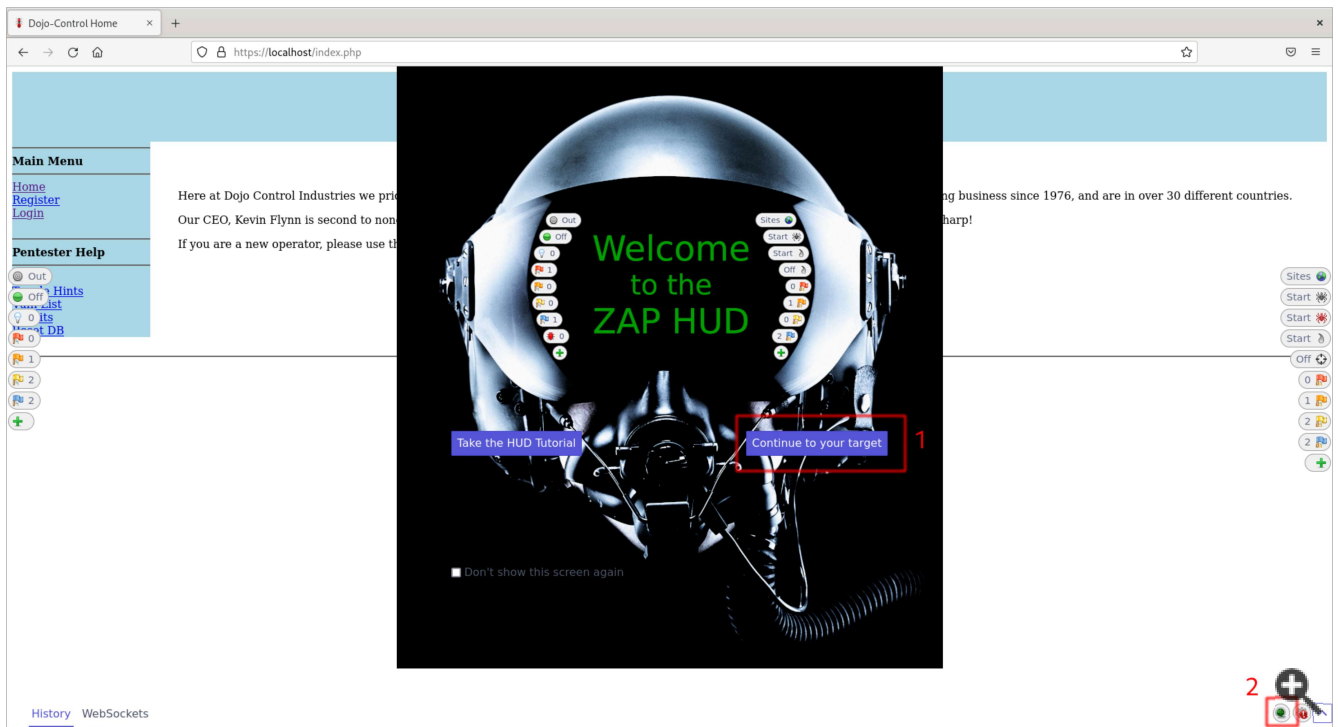
✗ Firefoxではログインを試みることができるが、ZAPは何も認識しない

Firefoxのプロキシがオフになっている可能性があります。上記のセクションをやり直してください。

ZAP HUDは使用しないので無効にします

ボタンをクリックして Continue to your target HUDスプラッシュ画面を閉じます

右下にある緑色の「有効/無効」ボタンをクリックします。



john ユーザー名とパスワードを使ってDojoControlのウェブサイトログインしてみましょう。 letmein

ZAPに戻り、履歴タブでリクエストを探します

✓ 成功

履歴タブに表示されるトラフィックは、画面によって異なる場合があります。履歴タブはZAPウィンドウの下部にあります。解像度が低すぎるとタブが表示されなかったり、タブの下にあるコンテンツが表示されない場合があります。その下のトラフィックリストを表示するスペースが足りない場合は、そのセクションの上にあるハンドルを上ドラッグしてスペースを確保してください。

Id	Req. Timestamp	Method	URL	Code	Reason	RTT	Size Resp. Body	Highest Alert	Note	Tags
1	7/29/20, 7:55:21 PM	GET	http://localhost/index.php?page=login.php	200	OK	41 ms	2,941 bytes	Medium		Form, Password, S...
4	7/29/20, 7:56:55 PM	GET	https://firefox.settings.services.mozilla.com/v1...	200	OK	382 ...	15,826 bytes	Low		JSON
11	7/29/20, 7:56:56 PM	GET	https://firefox.settings.services.mozilla.com/v1...	200	OK	123 ...	726 bytes	Low		JSON
14	7/29/20, 7:56:56 PM	GET	https://firefox.settings.services.mozilla.com/v1...	200	OK	120 ...	430 bytes	Low		JSON
16	7/29/20, 7:56:57 PM	GET	https://firefox.settings.services.mozilla.com/v1...	200	OK	120 ...	665 bytes	Low		JSON
19	7/29/20, 7:56:57 PM	GET	https://firefox.settings.services.mozilla.com/v1...	200	OK	82 ms	12 bytes	Low		JSON
21	7/29/20, 7:56:57 PM	GET	https://content-signature-2.cdn.mozilla.net/ch...	200	OK	355 ...	5,344 bytes	Low		
30	7/29/20, 7:57:30 PM	GET	http://localhost/	200	OK	38 ms	3,068 bytes	Medium		Script, Comment
32	7/29/20, 7:58:33 PM	POST	http://localhost/index.php?page=login.php	200	OK	12 ms	3,005 bytes	Medium		Form, Password

履歴を上下にスクロールして、リクエストのメソッド列 **POST** とリクエスト/レスポンスのペアのURL列を確認すると、次のようになります。

http://localhost/index.php?page=login.php

? ZAP では HTTP が表示され、Firefox では HTTPS が表示されるのはなぜですか?

ローカルホストのウェブサーバーはTLSを使用するように設定されていないため、HTTPSを使用してサイトにアクセスできません。しかし、Firefoxは現在すべてのウェブサイトでHTTPSの使用を必須としているため、ZAPへの接続にはTLSプロキシトンネル（FirefoxのHTTPSインジケーター）内でHTTPSを使用します。ZAPがDojoControlへのアクセスにHTTPSを試みると失敗し、その後HTTPを試みると接続に成功します。

▲ 今後はControlThings VMでFirefoxを使用する

これがうまくいき、「履歴」タブにトラフィックが表示されていれば、ControlThings VM でほとんどのウェブサイトで ZAP を使用できるはずです。必要なのは、ZAP を使用するかどうかに応じて、Firefox のプロキシ設定をオン/オフにするだけです。その後 Firefox を使用しようとして、プロキシがトラフィックを拒否しているというメッセージが表示される場合は、Firefox のプロキシ設定をオフにするか、ZAP を起動してください。

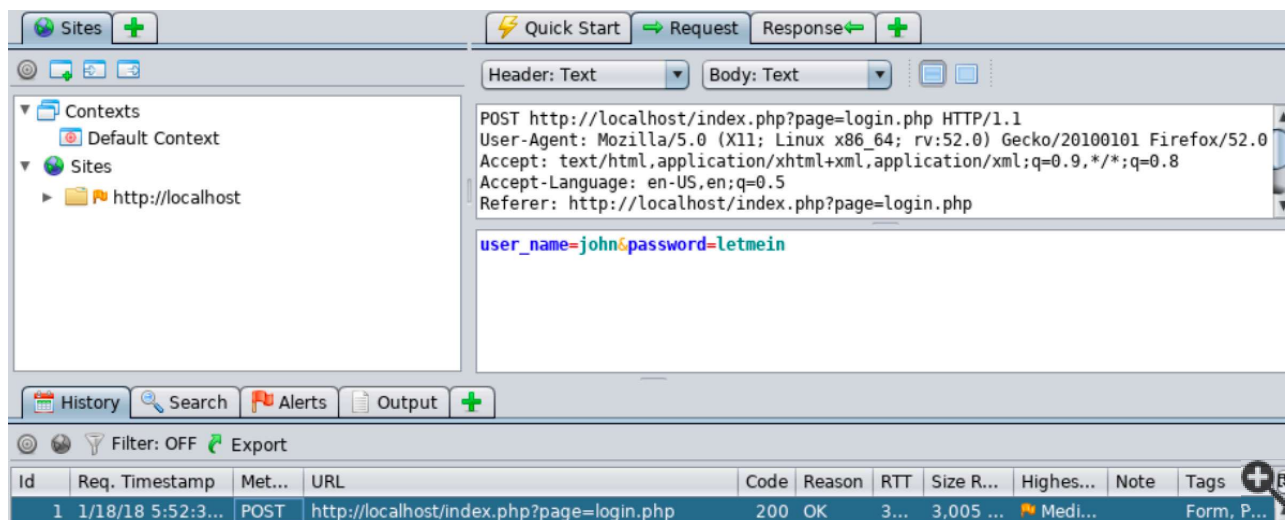
6. パスワードのファジング

ZAPを使用すると、生のHTTPトラフィックがどのように見えるかを確認できます。前のステップで見つけた**login.php**への**POST**リクエストのリクエストとレスポンスの内容を確認しましょう

POST リクエストをクリックして `http://localhost/index.php?page=login.php` ハイライト表示します

ZAPウィンドウの右上隅にある **Request** タブをクリックします

✓ 成功



「リクエスト」タブでは、ログイン時にFirefoxがDojo-Controlウェブサイトへ送信した生のHTTPリクエストを確認できます。「リクエスト」タブには2つのセクションがあります。上部のセクションは**HTTPヘッダー**です。ユーザー名とパスワードがある下部のセクションは**POSTペイロード**と呼ばれます。上記の成功画像をよく見ると、POSTペイロードに2つのパラメータがあることがわかります。1つはユーザー名用、もう1つはパスワード用です。これらのパラメータと値のペアはそれぞれ、アンパサンド & 文字で区切られています。「私のパスワード推測」では、私がパスワードを推測したことがわかります `letmein`（またはスペースなしの「let me in」）。これはたまたまジャスティンのお気に入りのパスワードです。;-)

6.1. ファズロケーション

履歴から自分のログイン試行を1つ見つける

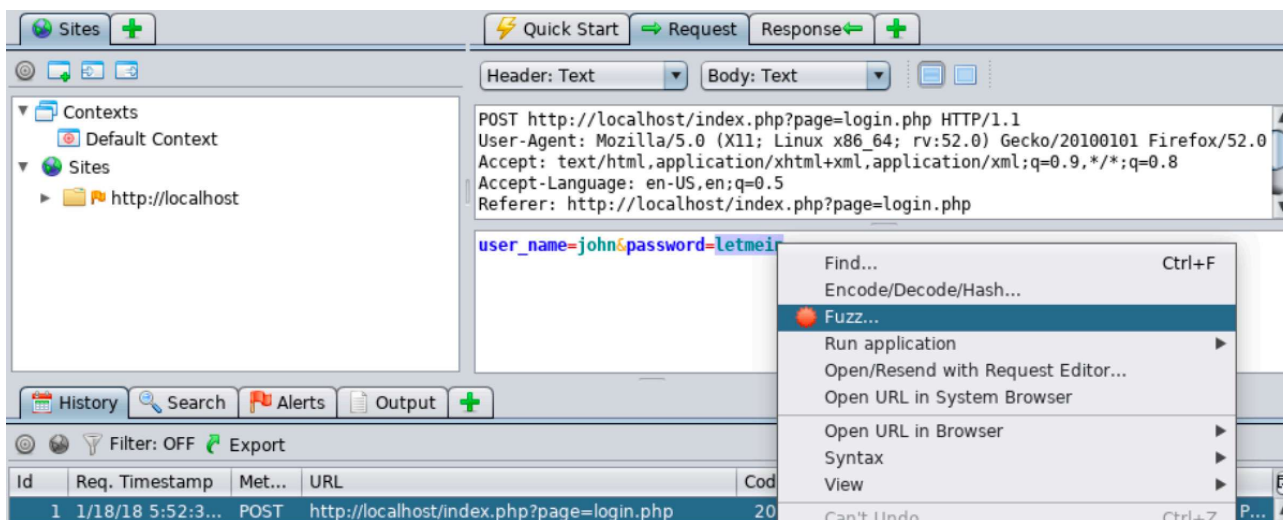
リクエストのPOSTペイロードセクションに、パスワードの推測値がどこにあるか確認してください。ラボの次のステップに進む前に、このリクエストの1つを見つけない必要があります。このリクエストをファジングのテンプレートとして使用するためです。上のスクリーンショットのように`letmein`と入力する必要はありませんが、ZAPで見つけるには、Firefoxで推測したパスワードがわかる必要があります。

パスワードの推測値を含むサンプルリクエストができれば、ZAPに同じログインリクエストをパスワードだけを変えて何千回も送信するように指示します。これはパスワードファジングと呼ばれ、パスワードに予想される値に近い値を提供することです。

推測したパスワードをダブルクリックしてハイライトします

ハイライト表示されたパスワードの推測を右クリックし、 **Fuzz...**

例



これは、このリクエストをファジング試行のテンプレートとして使用することをZAPに伝え、試行ごとに、強調表示されたテキストを新しいパスワード推測に置き換えるように指示します。開いたウィンドウでは、他のファジング場所を選択できますが、それは必要ありません。強調表示されたパスワード推測を何に置き換えるかをZAPに伝えるだけです

6.2. ペイロードの選択

ControlThings Platformには、ファザーで利用できる多数のワードリストが付属しています。このラボで最も興味深いのは、**ジョン・ザ・リッパー**のデフォルトパスワードリストです。

ファザーウィンドウの右側で、 **Payloads**

ウィンドウが開きます **Payloads**。

ペイロードウィンドウの右側で、 **Add**

ウィンドウが開きます **Add Payloads**。

Type ウィンドウのフィールドで **Add Payloads**、 **File**

ボタンをクリックして **Select** ファイルを選択してください

`john.txt` ここで、ControlThings Platform 内のファイルに移動する必要があります。

`Samples > Fuzzing > fuzzdb > wordlist-user-passwd > passwd > john.txt`

選択したらボタン `john.txt` をクリックしてください **Open**

フォルダー内の他の単語リスト `passwd` もパスワード推測に使用するのに適していますが、それらは長いリストであり、実行に非常に時間がかかるため、このラボでは必要ありません。

ペイロード プレビュー ウィンドウを見ると、ZAP が `john.txt` ファイルから John のパスワードを推測するために使用するパスワードの短縮リストが表示されます。

注

ちなみに、これは **John the Ripper** `john.txt` というツールに由来しています。これはパスワードハッシュを解読するために使用されるツールです。90年代に作成されましたが、一般的なパスワードのリストは今日でも驚くほど正確であり、人間が失敗から学ぶことがいかにできないかを物語っています

Add この単語リストを **Payloads** ウィンドウに追加するにはクリックしてください

クリックしてウィンドウ **OK** を閉じます **Payloads**

クリックし **Start Fuzzer** でファジングプロセスを開始します

ZAP は、単語リスト内の項目ごとに 1 回のファジング試行を実行するはずで `john.txt`。また、ZAP のメインウィンドウ下部に「Fuzzer」タブが開き、すべてのファジング試行の進行状況を監視できます。

6.3. 結果の分析

正しいパスワードが見つかったかどうかを判断するために、Fuzzの出力を調べる方法は2つあります。すべてのレスポンスに異常がないか探るか、ログイン試行の成功または失敗を示す既知の指標を探することができます。異常を探すには、レスポンスのステータス、サイズ、場合によってはレスポンス時間（RTT）の違いを調べることができます

ファズ結果を並べ替える Size Resp. Body

列ヘッダーをクリックすると、**Size Resp. Body** 列が降順でソートされます。一番上までスクロールして、ファジングの試行ごとに結果のサイズが異なるかどうかを確認してください。

✓ 成功

The screenshot shows the OWASP ZAP 2.9.0 interface. The 'Messages' tab is active, displaying a list of messages. The 'Size Resp. Body' column is sorted in descending order. The top message (Task ID 96) shows a response size of 336 bytes and a body size of 2,994 bytes, which is significantly larger than the other messages (3,005 bytes). The 'Payloads' column for this message shows 'monkey'.

Task ID	Message Type	Code	Reason	RTT	Size Resp. Header	Size Resp. Body	Highest Alert	State	Payloads
20	Fuzzed	200	OK	14 ms	228 bytes	2,941 bytes			
96	Fuzzed	200	OK	16 ms	336 bytes	2,994 bytes			monkey
0	Original	200	OK	12 ms	229 bytes	3,005 bytes	Medium		
1	Fuzzed	200	OK	168 ms	229 bytes	3,005 bytes			12345
2	Fuzzed	200	OK	106 ms	229 bytes	3,005 bytes			abc123
3	Fuzzed	200	OK	126 ms	229 bytes	3,005 bytes	Reflected		password
4	Fuzzed	200	OK	127 ms	229 bytes	3,005 bytes			computer
5	Fuzzed	200	OK	92 ms	229 bytes	3,005 bytes			123456
6	Fuzzed	200	OK	17 ms	228 bytes	3,005 bytes			tigger

Size Resp. Body 1つか2つを除いて、ほとんどのサイズはバイト前後であることに気づくでしょう 3,005。1つはレスポンスヘッダーのサイズが 2,994 バイト前後です。正確なサイズは数バイト異なる場合がありますが、いずれにしても、他のリクエストとはサイズが異なるリクエストが1つか2つあるはずです

異なるサイズのファジング結果で、右端の列を見ると、このファジング試行にの **PayLoads** パスワード推測が使用されたことがわかります。monkey

Firefoxに戻り、monkey ユーザーのパスワードを試してください john

注

Set-Cookie ログインに成功したと思われるファズ試行を選択した場合、ZAPの右上隅にあるHTTPレスポンスタブでセッションIDを確認できます。ヘッダーセクション（レスポンスタブの上部）で、で始まる行を探します

これでログインできるはずです。

6.4 Firefoxでプロキシ設定を無効にする

ZAPの使用は終了したので、ZAPを開かなくてもブラウザが機能することを確認しましょう。

Firefoxのプロキシ設定を開き、「プロキシなし」に設定します

? それはどうすればいいですか?

Firefoxの設定を開く

Firefoxの右上隅にある  アイコンをクリックします

メニューから設定を選択します

上部の「設定で検索」ボックスで、proxy

これにより、設定が1つの項目に絞り込まれます。

✓ 成功



設定ボタンをクリックします

プロキシなしを選択

[OK]をクリックします

設定タブを閉じる

ZAPがまだ閉じられていない場合は閉じ、Webサイトにアクセスして、ZAPを開かずに動作することを確認します。

7. ボーナスチャレンジ

他の参加者のラボの完了を待っている方、あるいはこのラボで紹介された概念をさらに深く探求したい方は、以下のアイデアを試してみてください。これらのチャレンジにはチュートリアルは用意されていませんが、もし行き詰まってしまい、コース作成者のJustinに自分の取り組みを説明できれば、喜んでヒントを教えてください。justin [@controlthings.io](mailto:justin@controlthings.io)までメールでお問い合わせください。

adrian ユーザー、ed、のパスワードをファジングしてみる admin

Set-Cookie ログインに成功するたびに、HTTP 応答のヘッダーが表示されますか？

これらの実装方法にセッション管理の脆弱性がないか確認できますか？

Wiresharkを使用してインターフェースをキャプチャし、最初のHTTPリクエストをキャプチャしたときに言及した Loopback: lo 奇妙な Firefox -> HTTPS -> ZAP -> HTTP ->シナリオをキャプチャします。 DojoControl